Challenge 6 – Uso non corretto di fillable (mass assignment)

Se in $fillable del modello User ci sono anche campi di ruolo (is_admin, ecc.), e il profilo aggiorna l'utente con tutti i dati della request, qualcuno può aggiungere campi nascosti dal browser e alzarsi i privilegi.

Prova prima della mitigazione-

Ho creato una pagina Profile (vista, rotte, controller) come da traccia, volutamente vulnerabile ($request->all()).
Loggato come user@aulab.it, da Ispeziona ho aggiunto <input type="hidden" name="is_admin" value="1"> e salvato. È comparso Admin panel.



Http > Controllers > ProfileController.php

```php
{

    public function update(Request $request)
    {
        $request->validate([
            'name' => 'required|string|max:255',
            'email' => 'required|email|max:255',
            'password' => 'nullable|string|min:8',
        ]);

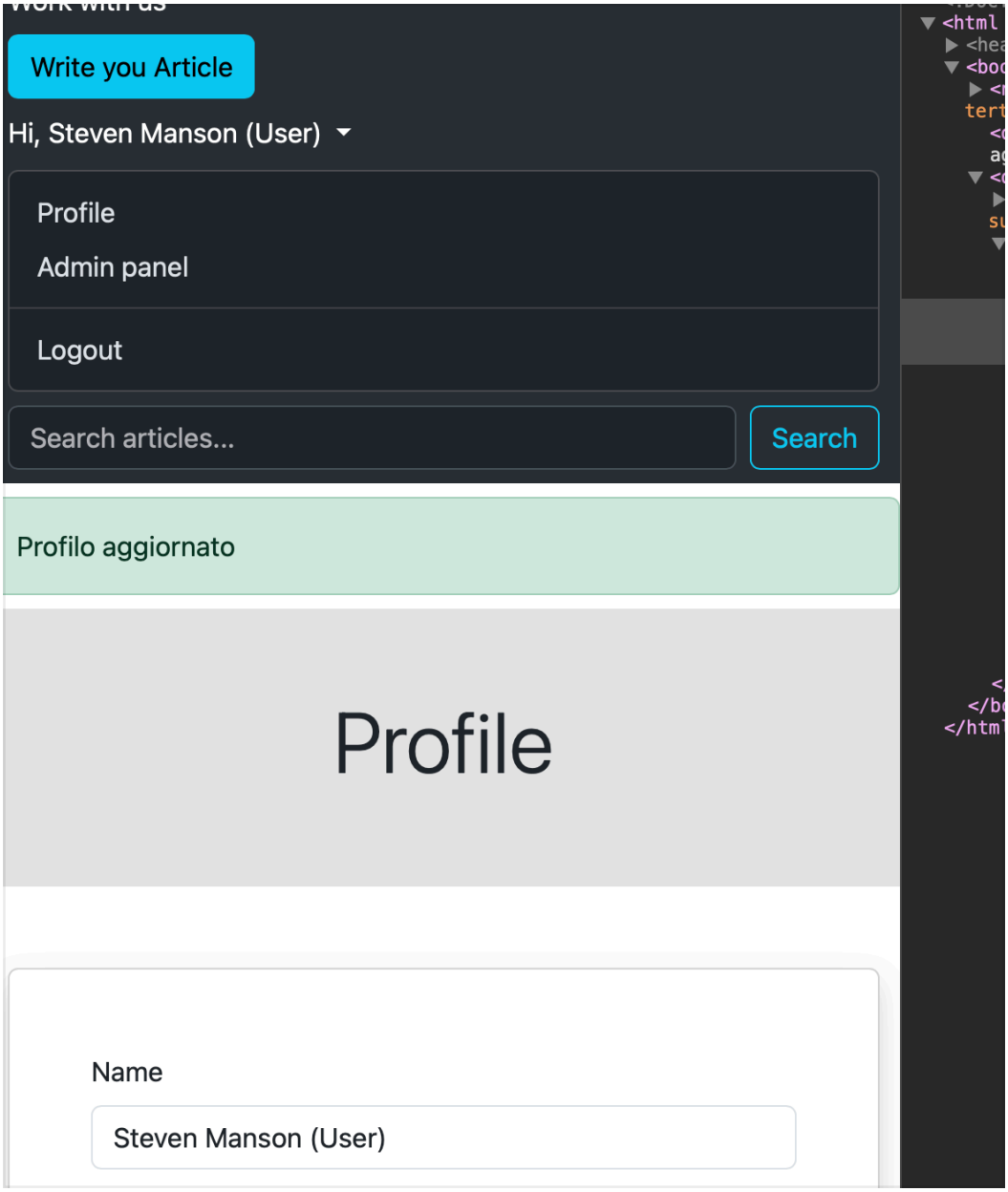
        $user = Auth::user();

        // Volutamente vulnerabile (mass assignment): prende tutti i campi della request
        $data = $request->all();

        if (!empty($data['password'])) {
            $data['password'] = Hash::make($data['password']);
        } else {
            unset($data['password']);
        }

        $user->update($data);

        return redirect()->route('profile.edit')->with('message', 'Profilo aggiornato');
    }
}
```



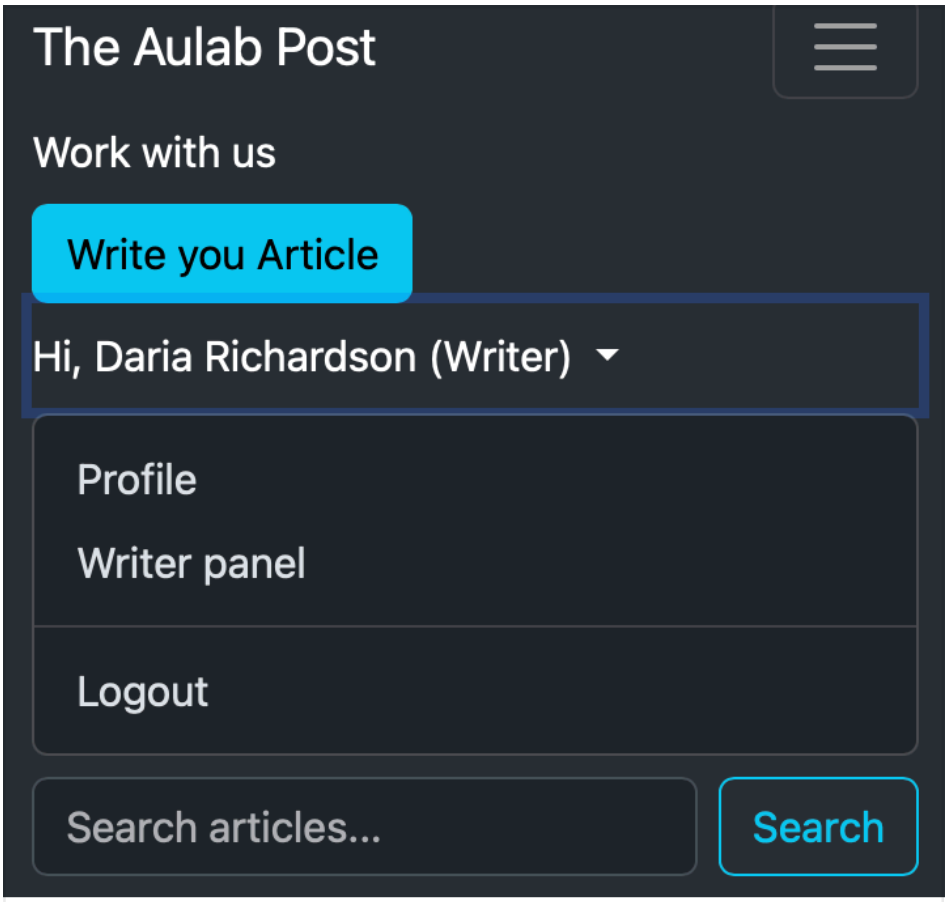
Mitigazione-

In User.php ho lasciato in $fillable solo name, email, password.



Prova dopo la mitigazione-

Con writer@aulab.it ho rifatto la stessa modifica Ispeziona. Profilo aggiornato, ma **niente** Admin panel (solo Writer panel).



Profilo aggiornato

Profile